

a typical DDoS attack, because a DRDoS attack has more machines to share the attack—the attack is more distributed and so creates a greater volume of traffic. Figure 2 depicts a DRDoS attack.

How DDoS attacks are performed

A DDoS attack has to be carefully prepared by the attackers. They first recruit the zombie army, by looking for vulnerable machines, then break into them (usually via Metasploit), and install attack tool-kits. The attacker next establishes communication channels between machines, so that they can be controlled and engaged in a coordinated manner. This is done using either a handler/zombie architecture, or an IRC-based command-and-control (C&C) channel. Once the DDoS network is built, it can be used to attack various targets as often as desired.

But, the first step for attackers is to find machines that they can compromise. To maximise the yield, they will recruit machines that have good connectivity and ample resources, and are poorly maintained. Unfortunately, many of these exist within the pool of the millions of Internet hosts. The process of looking for vulnerable machines is called scanning. The attackers send a few packets to the system, to see whether it is alive (online) and vulnerable. If so, the attackers will attempt to break into the machine. After breaking in, they will try to install malicious code, or a ‘bot’ on the machine, which will give them complete reverse control over the machine. The attacker can repeat the scan-and-infect process to build big attack networks. The mechanism of propagating malicious code to compromised machines is classified into three types. These are given below.

Central source propagation

In this method, after discovering a vulnerable system that will become one of the zombies, the attackers take control over the system and download an attack tool-kit from a different website (a central source) to the newly exploited system. After the tool-kit is transferred, an automatic installation of the attack tools takes place on this system. That initiates a new attack cycle, where the newly infected system looks for other vulnerable computers on which it can install the attack tool-kit, using the same process as the attackers. Like other file-transfer mechanisms, this mechanism commonly uses HTTP, FTP, and *remote-procedure call* (RPC) protocols. A representation of this is shown in Figure 3. From the attacker’s perspective, such central sources can be easily identified and disabled by security professionals; hence, this method is not used much nowadays.

Back-chaining propagation

In this mechanism, the attack tool-kit is transferred to the newly compromised system from the attackers’ system. More specifically, the attack tool-kits that are installed on the attackers’ system include special methods for accepting

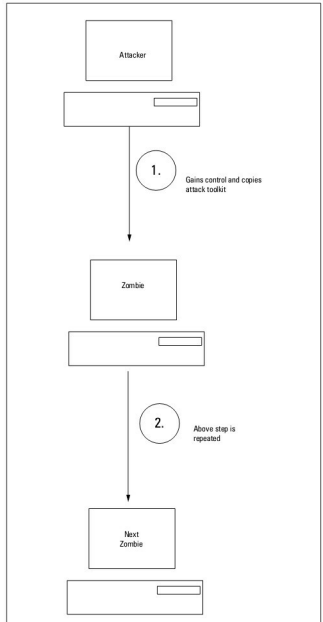


Figure 5: Autonomous propagation method

a connection from the compromised system, and sending a file to it that contains the attack tools. This back-channel file copy can be supported by simple port listeners that copy file contents, or by full intruder-installed Web servers, both of which use the Trivial File Transfer Protocol (TFTP). Figure 4 represents this form of attack.

Autonomous propagation

In this method, the attackers transfer the attack tool-kit to the newly compromised system at the exact moment that they break into that system. This method differs from the previously mentioned methods in that the attack tools are planted into the compromised host by the attackers themselves, and not by an external file source. Figure 5 shows autonomous propagation.